

Audit-Tail Final Report

Project: `vulnerable-invoice-service` · Stage 5 (aggregate) · Generated 2026-07-11 · Health Score: **75 / 100** Grade B — minor issues

Executive summary

- **23** dependencies scanned · **74** CVE findings across **7** vulnerable dependencies (16 CRITICAL / 44 HIGH / 13 MEDIUM / 1 LOW) at scan time (`source_sha` `61ed8c3`).
- **Remediation:** PR [#74](#) (`fix/depSCAN-20260711-052154`) bumped `log4j-core/api`, `jackson-databind`, `jackson-core/annotations`, `protobuf-java`, `guava`, `commons-io`, and `commons-lang3` — **73 of 74 CVEs cleared**. 1 residual MEDIUM CVE remains with no upstream fix yet.
- **Supply-chain:** BLOCK — untrusted HTTP Maven repository still declared in `pom.xml` (issue [#5](#)) + `mysql-connector-java` GPL-2.0-with-FOSS-exception license violation (issue [#73](#)). Typosquat check now **passes** — the planted `com.fastxml.jackson.core` coordinate was removed in PR [#74](#).
- **Licenses:** 1 violation (GPL-2.0-with-FOSS-exception on `mysql-connector-java`, MAJOR_REVIEW — not auto-fixable, tracked in issue [#73](#)).
- **Tests:** 2/2 passing on PR [#74](#).
- **Latest gate outcome (Stage 4, PR [#74](#)):** BLOCK — CVE check and tests pass; supply-chain audit fails on the 2 findings above. Human action required before merge.

Health score breakdown

Factor	Deduction
Unresolved CRITICAL CVEs (0 × -15)	0
Unresolved HIGH CVEs (0 × -8)	0
Unresolved MEDIUM CVEs (1 × -2)	-2
Supply-chain BLOCK findings (2 × -10)	-20
Outdated major-version deps (1 × -3, <code>junit-jupiter</code>)	-3
Score (floored at 0)	75 / 100

To reach a clean 100: replace/remove the `internal-untrusted-mirror` HTTP repository in `pom.xml` , resolve the `mysql-connector-java` GPL license flag (license exception or driver swap), and bump `junit-jupiter` to a current major version. The residual MEDIUM CVE in `jackson-databind` has no upstream fix yet and should be re-checked on the next scan.

Top risks (ranked)

Coordinate	Risk	Band	Top CVE	Status
<code>mysql-connector-java:8.0.30</code>	—	supply-chain BLOCK	GPL-2.0-with-FOSS-exception license	MAJOR_REVIEW (issue #73)
<code>internal-untrusted-mirror</code> repo (<code>pom.xml</code>)	—	supply-chain BLOCK	untrusted HTTP source	open (issue #5)
<code>com.fasterxml.jackson.core:jackson-databind:2.18.8</code>	—	MEDIUM	CVE-2026-54515 (no fix available)	monitor

org.junit.jupiter:junit-jupiter	—	outdated (major)	n/a	routine bump recommended
---------------------------------	---	------------------	-----	--------------------------

Remediation activity (PR #74)

Dependency	Change	CVEs cleared	Merged?
log4j-core / log4j-api	2.14.1 → 2.25.4	7 (incl. CVE-2021-44228 Log4Shell)	open, pending gate
jackson-databind	2.9.8 → 2.18.8	54	open, pending gate
jackson-core / jackson-annotations	→ 2.18.8	3 (incl. CVE-2025-52999)	open, pending gate
protobuf-java (transitive, pinned)	3.19.4 → 3.25.5	4 (incl. CVE-2024-7254)	open, pending gate
guava	24.1.1-jre → 32.0.0-android	2 (CVE-2023-2976, CVE-2020-8908)	open, pending gate
commons-io	2.4 → 2.14.0	2	open, pending gate
commons-lang3	3.4 → 3.18.0	1 (CVE-2025-48924)	open, pending gate
com.fastxml.jackson.core typosquat coordinate	removed	n/a (supply-chain)	open, pending gate
mysql-connector-java	not touched (GPL flag, not safely auto-fixable)	n/a	MAJOR_REVIEW issue #73

Gate (Stage 4) — current verdict on PR #74: BLOCK

Check	Result
Unit tests	PASS (2/2)
OWASP/CVE check (0 unresolved CRITICAL/HIGH)	PASS (73/74 cleared, 1 residual MEDIUM)
Supply-chain audit	FAIL (BLOCK — untrusted repo + GPL license)

Trend vs. previous run (2026-06-10)

Metric	Previous	Current	Δ
Health score	0 / 100 (D)	75 / 100 (B)	+75
Unresolved CRITICAL CVEs	4	0	−4
Unresolved HIGH CVEs	several	0	cleared
Supply-chain BLOCK findings	2 (typosquat + untrusted repo)	2 (untrusted repo + GPL license)	typosquat resolved, license flag now surfaced
Open remediation PR	proposed	#74 opened, awaiting merge	—

Human follow-ups (ordered)

1. Remove/replace the untrusted HTTP repository `internal-untrusted-mirror` in `pom.xml` (issue #5) — supply-chain gate blocker.
2. Resolve the `mysql-connector-java` GPL-2.0-with-FOSS-exception license violation — legal review or driver swap (issue #73) — supply-chain gate blocker.
3. Once both are resolved, re-run the Stage 4 gate on PR #74; a PASS verdict makes it ready for human merge.
4. Routine: bump `junit-jupiter` to a current major version; monitor `jackson-databind` for an upstream fix to CVE-2026-54515.

Aggregated from `depscan-report.json` , `depscan-risk-report.json` , `depscan-supplychain-audit.json` , and the PR #74 gate review. Generated by the Dependency & Supply-Chain Plugin — Stage 5.